WEB01 | Remediation verification

Two real security-header findings · Baseline: 24–25 Oct 2026 · Rescan: 26 Oct 2026

80	93	10 → 8	2
imported findings	EPSS-enriched CVEs	operational backlog	verified fixes

Change summary

Flask security responses now include **X-Frame-Options: DENY** (anti-clickjacking) and **X-Content-Type-Options: nosniff** (MIME-sniffing control). These address the two WEB01 findings originally reported by the scoped OWASP ZAP baseline.

Observed before and after

Evidence	Before	After
Homepage `/`	200 OK; both headers missing	200 OK; `DENY` and `nosniff` present
CSS `/static/style.css`	200 OK; both headers missing	200 OK; both headers present
ZAP alert types for WEB01	CSP, anti-clickjacking, server leak, X-Content-Type-Options	CSP and server leak remain; two header alerts absent

Database evidence

`pp_actions` recorded `ZAP-c6ed5f83117c110d` and `ZAP-d04e9ebd6c5df4ec` as verified. `pp_exec_remediation` reported **2 verified_with_evidence**; outstanding imported operational items fell from **10 to 8**.

Files to retain

`evidence/baseline/2026-10-24-ZAP-Report-.html`
`evidence/remediation/web01-zap-rescan.html`
`evidence/remediation/web01-before-headers.txt` and `web01-after-headers.txt`
`evidence/remediation/web01-css-before.txt` and `web01-css-after.txt`
`screenshots/zap-web01-verified-remediation.png`

Verification boundaries

This is an evidence-backed verification of **two header fixes for tested endpoints**, not a claim that WEB01 is completely secure. CSP and server version disclosure remain in the new ZAP report; the Flask lab is deliberately vulnerable. The existing scanner data and risk scores still represent a partial assessment.